Rapport de Test d'Intrusion avec Burp Suite

Mission : OWASP Juice Shop

Nom Prénom

12 août 2025

Table des matières

1 Introduction **2**

2 Présentation de Burp Suite **3**
2.1 Définition 3
2.2 Modules principaux 3
2.3 Types de failles détectables 4

3 Mise en place de l'environnement de test **5**
3.1 Choix du système 5
3.2 Installation de Docker 5
3.3 Déploiement de Juice Shop 5

4 Injection SQL (SQLi) **6**
4.1 Définition 6
4.2 Exemple de requête vulnérable 6
4.3 Risques principaux 6
4.4 Test sur Juice Shop 6

5 Faille Cross-Site Scripting (XSS) **9**
5.1 Définition 9
5.2 Types de XSS 9
5.3 Exemple de charge utile 9
5.4 Risques principaux 9
5.5 Test sur Juice Shop 9

Chapitre 1

Introduction

L'objectif de cette mission est de réaliser un test d'intrusion sur une application web. Pour cela, il est impératif d'utiliser une application volontairement vulnérable et pour laquelle nous disposons d'une autorisation explicite. En effet, la législation interdit de procéder à des tests d'intrusion sur une application réelle sans accord préalable.

Afin de répondre à ce besoin, j'ai déployé l'application **OWASP Juice Shop**, développée spécifiquement pour l'apprentissage et l'entraînement aux tests de sécurité. La mission imposait également l'utilisation de **Burp Suite** comme outil principal d'analyse et d'exploitation des vulnérabilités.

Pour mettre en place cet environnement, j'ai installé Burp Suite sur une machine virtuelle Debian 12 et déployé Juice Shop via Docker.

FIGURE 1.1 – schéma expliquant le role d'un proxy

Chapitre 2

Présentation de Burp Suite

2.1 Définition

Burp Suite est un outil professionnel d'audit et de test de sécurité des applications web. Il fonctionne principalement comme un **proxy** entre le navigateur de l'attaquant et l'application cible.

Le rôle du proxy est d'intercepter les requêtes HTTP/HTTPS envoyées par le navigateur avant qu'elles ne parviennent à la cible, ainsi que les réponses retournées par celle-ci. Cela permet de visualiser, analyser et modifier le contenu de ces échanges en temps réel.

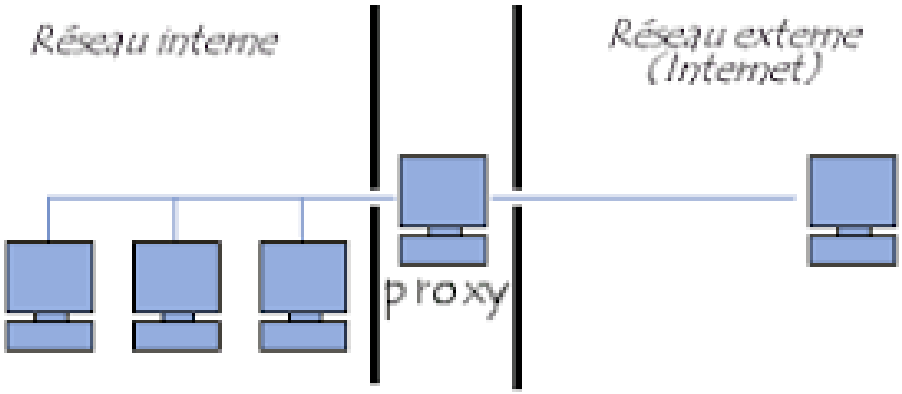

FIGURE 2.1 – schéma expliquant le role d'un proxy

2.2 Modules principaux

- **Proxy** : interception et modification des requêtes/réponses.
- **Repeater** : modification et réexécution manuelle de requêtes.
- **Intruder** : automatisation d'attaques sur des points précis.
- **Scanner** (version Pro) : détection automatique de failles.
- **Comparer** et **Decoder** : analyse et décodage de données.

2.3 Types de failles détectables

— Injection SQL (SQLi)
— Cross-Site Scripting (XSS)
— Mauvaises configurations serveur
— Fuites d'informations sensibles

Chapitre 3

Mise en place de l'environnement de test

3.1 Choix du système

J'ai choisi **Debian 12** comme système d'exploitation pour mon environnement de travail, bien qu'Ubuntu ou Kali Linux soient également adaptés. Debian est ici privilégié pour sa stabilité et ma familiarité avec cet OS.

3.2 Installation de Docker

L'application Juice Shop étant distribuée sous forme de conteneur, il est nécessaire d'installer Docker. Commande d'installation (en root) :

```
apt update && apt install docker.io -y
```

(Insérer capture d'écran ici)

3.3 Déploiement de Juice Shop

Une fois Docker installé, le déploiement de Juice Shop s'effectue avec :

```
docker run --rm -p 3000:3000 bkimminich/juice-shop
```

Le port **3000** est ici choisi pour l'accès à l'application via le navigateur.
(Insérer capture d'écran ici)

Chapitre 4

Injection SQL (SQLi)

4.1 Définition

L'injection SQL est une vulnérabilité permettant à un attaquant d'injecter des commandes SQL malveillantes dans les requêtes d'une application afin d'accéder, de modifier ou de supprimer des données.

4.2 Exemple de requête vulnérable

Requête légitime :

```
SELECT * FROM utilisateurs WHERE nom = 'nathan' AND motdepasse = '
    1234';
```

Requête modifiée par un attaquant :

```
'␣OR␣1=1␣--
```

Ce qui devient :

```
SELECT * FROM utilisateurs WHERE nom = '' OR 1=1 --' AND motdepasse
     = '';
```

La condition `1=1` étant toujours vraie, la requête retourne tous les utilisateurs, permettant de se connecter sans mot de passe valide.

4.3 Risques principaux

- Accès non autorisé à des comptes (y compris administrateur)
- Lecture, modification ou suppression de données
- Compromission complète de la base de données

4.4 Test sur Juice Shop

En utilisant Burp Suite, j'ai intercepté la requête de connexion et injecté la charge utile suivante :

```
'␣OR␣1=1␣--
```

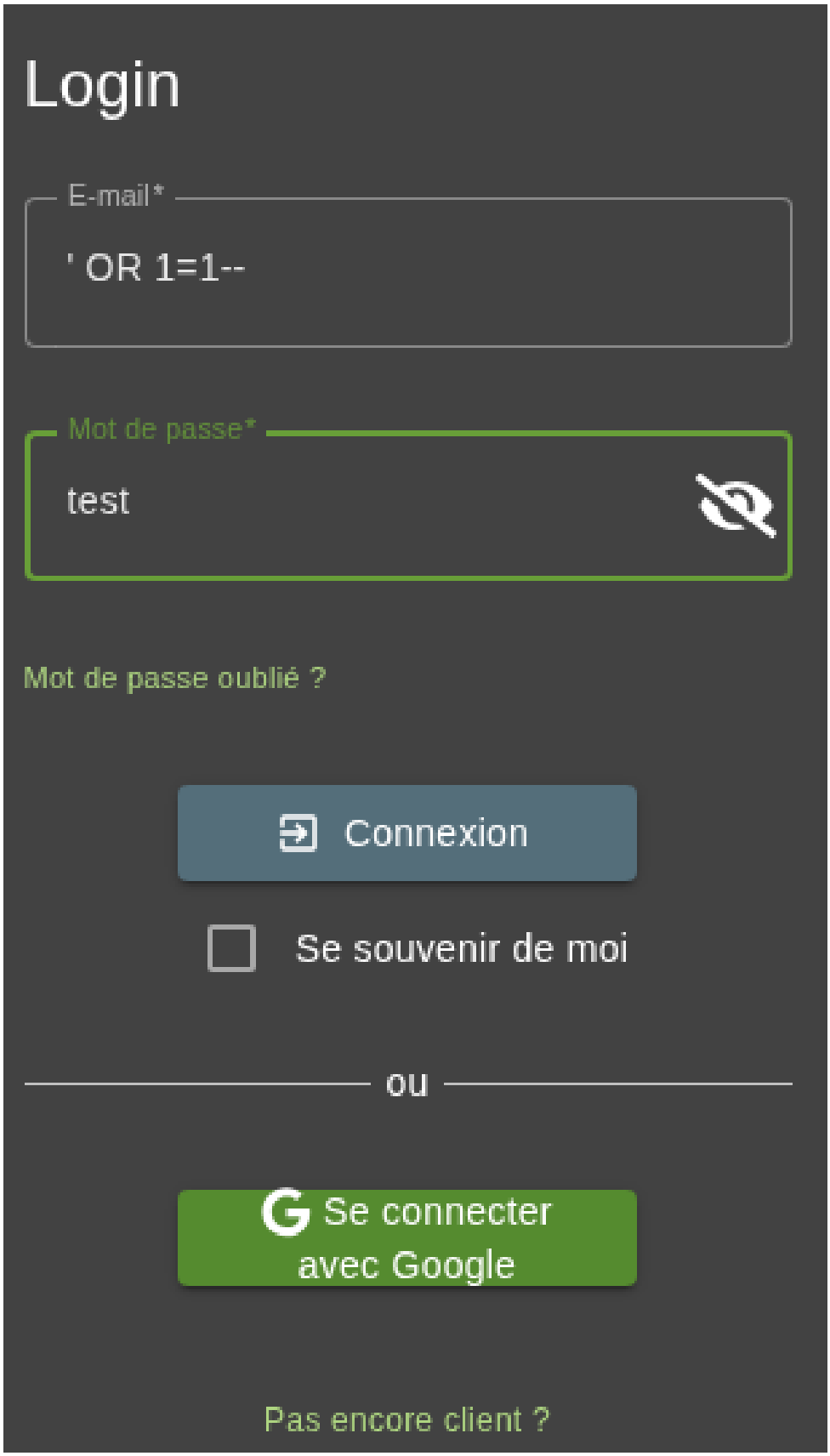

FIGURE 4.1 – résultat de l'injection sql

Résultat : connexion réussie au compte administrateur de Juice Shop, démontrant que l'application est vulnérable à l'injection SQL.

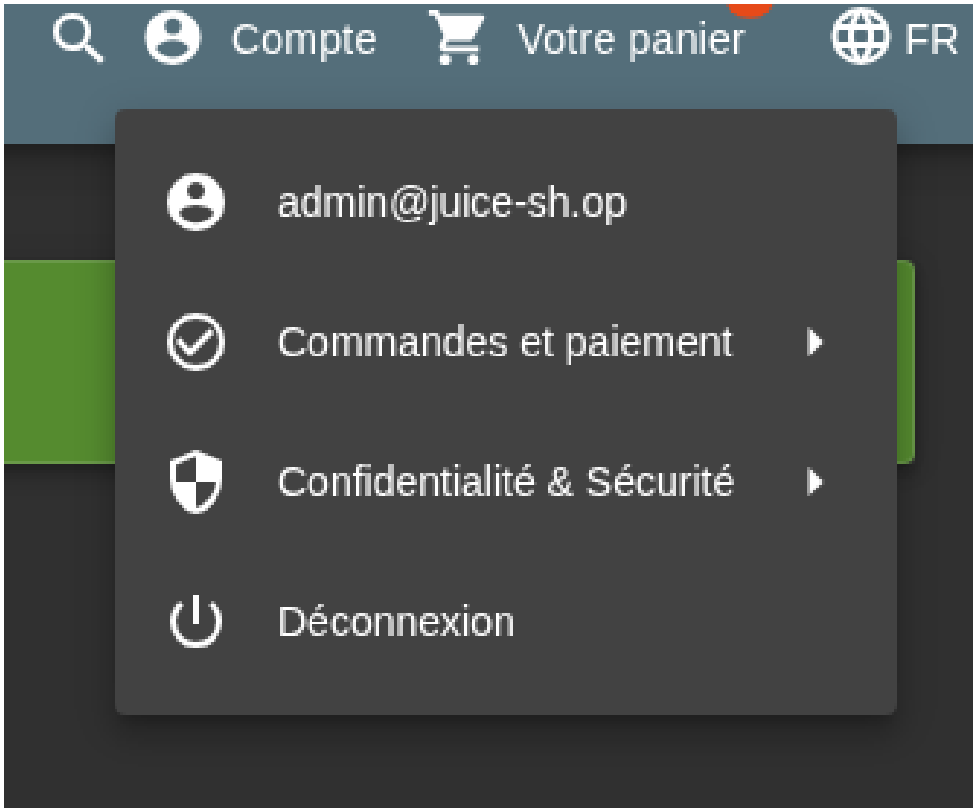

FIGURE 4.2 – résultat de l'injection sql

Chapitre 5

Faille Cross-Site Scripting (XSS)

5.1 Définition

La faille **Cross-Site Scripting** (XSS) permet à un attaquant d'injecter du code JavaScript malveillant dans une page web affichée à d'autres utilisateurs. Cette faille se produit lorsque les données fournies par l'utilisateur ne sont pas correctement filtrées ou échappées avant d'être affichées.

5.2 Types de XSS

- **XSS stocké** : le script est enregistré dans la base de données et exécuté à chaque affichage.
- **XSS réfléchi** : le script est contenu dans l'URL ou la requête et exécuté immédiatement dans la réponse.
- **XSS DOM-based** : l'injection se produit directement dans le code JavaScript côté client.

5.3 Exemple de charge utile

```
<script>alert('XSS')</script>
```

Ce code déclenche une boîte de dialogue JavaScript dans le navigateur de la victime.

5.4 Risques principaux

- Vol de cookies de session
- Défiguration du site
- Redirection vers des pages malveillantes
- Prise de contrôle du compte utilisateur

5.5 Test sur Juice Shop

Dans Juice Shop, j'ai identifié un champ de recherche vulnérable. À l'aide de Burp Suite, j'ai intercepté la requête et injecté :

```
<script>alert('XSS')</script>
```

Résultat : la boîte de dialogue s'est affichée dans le navigateur, confirmant la présence d'une faille XSS.

(Insérer captures d'écran ici)

Conclusion

Ce test a permis de mettre en évidence plusieurs failles critiques dans l'application volontairement vulnérable OWASP Juice Shop :

- Injection SQL (SQLi)
- Cross-Site Scripting (XSS)

Ces tests démontrent l'importance de filtrer et valider toutes les entrées utilisateur afin de prévenir ces vulnérabilités.